

ЗАТВЕРДЖЕНО  
Наказом ТОВ "Криптографічні Телесистеми"  
від \_\_\_\_ 2026 р. № \_\_\_\_  
(в редакції наказу ТОВ "Криптографічні Телесистеми"  
від \_\_\_\_ 2026 р. № \_\_\_\_)

Система електронного урядування  
«ERP/1»

ЦІЛЬОВИЙ ПРОФІЛЬ БЕЗПЕКИ

UA.46207985.СЗІ.ЦПБ-35

| №                                | Вимога з безпеки інформації                              | Вимога ГПБ                                                                      | ЦПБ           |                                                                                                                                                                                                                                                                                                                                       |
|----------------------------------|----------------------------------------------------------|---------------------------------------------------------------------------------|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                  |                                                          |                                                                                 | Захід захисту | Налаштований зміст заходу захисту                                                                                                                                                                                                                                                                                                     |
| 1. УПРАВЛІННЯ ДОСТУПОМ (АС) (АС) |                                                          |                                                                                 |               |                                                                                                                                                                                                                                                                                                                                       |
| 1                                | Управління обліковими записами                           | Параметр: account _management<br>Тип: boolean<br>Значення: true                 | АС-2          | Система забезпечує створення, активацію, зміну та видалення облікових записів відповідно до політик організації. Права доступу жорстко прив'язані до ідентифікатора працівника ('subject _employee') або ролі.                                                                                                                        |
| 2                                | Примусове застосування доступу (Access Enforcement)      | Параметр: access _enforcement<br>Тип: boolean<br>Значення: true                 | АС-3          | Усі запити до ресурсів системи примусово проходять через Policy Decision Point (PDP) модуля 'abac'. Прямий доступ до даних в обхід механізмів авторизації заборонено архітектурно.                                                                                                                                                    |
| 3                                | Принцип найменших привілеїв (Least Privilege)            | Параметр: least _privilege<br>Тип: boolean<br>Значення: true                    | АС-6          | Профілі безпеки і ролі конфігуруються таким чином, що користувачам надаються лише ті привілеї, які необхідні для виконання їхніх посадових обов'язків. Механізм дозволів 'abac' працює за принципом 'Default-Deny'.                                                                                                                   |
| 4                                | Блокування сеансу                                        | Параметр: session _lock_timeout<br>Тип: integer<br>Значення: 900                | АС-11         | Сеанс користувача автоматично блокується системою ('sync/n2o' session expiry) після визначеного періоду бездіяльності, вимагаючи повторної автентифікації.                                                                                                                                                                            |
| 5                                | Завершення сеансу                                        | Параметр: session _termination<br>Тип: boolean<br>Значення: true                | АС-12         | Користувач може ініціювати завершення сеансу (logout). Крім того, система примусово завершує сеанси при досягненні максимального часу життя токена або зміни контексту безпеки.                                                                                                                                                       |
| 6                                | Дозволені дії без ідентифікації чи автентифікації        | Параметр: permitted _unauthenticated _actions<br>Тип: boolean<br>Значення: true | АС-14         | Система явно визначає перелік відкритих сторінок та API-ендпойнтів (наприклад, портал входу або публічний довідник), доступних без автентифікації. Будь-які інші дії суворо заборонені.                                                                                                                                               |
| 7                                | Віддалений доступ                                        | Параметр: remote _access_control<br>Тип: boolean<br>Значення: true              | АС-17         | Віддалений доступ до системи керується додатковими політиками (наприклад, перевірка IP-адреси, VPN, mTLS), які інтегруються з 'sync/ca' та 'abac' для забезпечення безпеки доступу за межами захищеного периметра.                                                                                                                    |
| 8                                | Динамічне пов'язання атрибутів (заборона кешування)      | Параметр: dynamic _binding<br>Тип: boolean<br>Значення: true                    | АС-16(1)      | ABAC через компонент PIP (Policy Information Point) динамічно завантажує актуальні атрибути з контексту (наприклад, стан об'єкта 'object _process' чи профіль 'subject _employee' з KVS) безпосередньо в момент виконання запиту ('request'). Це гарантує, що рішення приймається на базі поточного, а не закешованого стану безпеки. |
| 9                                | Зміна значень атрибутів авторизованими особами через PAP | Параметр: authorized _changes<br>Тип: boolean<br>Значення: true                 | АС-16(2)      | Точка адміністрування PAP дозволяє уповноваженим адміністраторам (які пройшли перевірку PDP) змінювати правила ('rule'), політики ('policy') та кадрові атрибути співробітників, гарантуючи, що лише особи з належними повноваженнями можуть керувати системою доступу.                                                               |
| 10                               | Підтримка системою пов'язання атрибутів (KVS)            | Параметр: attribute _binding_support<br>Тип: boolean<br>Значення: true          | АС-16(3)      | Інфраструктура бази даних 'sync/kvs' нативно інтегрована з моделями 'abac.hrl'. Система зберігає зв'язки між суб'єктами та атрибутами на рівні записів (records), що не підлягають несанкціонованому перезапису.                                                                                                                      |

| №  | Вимога з безпеки інформації                                       | Вимога ГПБ                                                                    | ЦПБ           |                                                                                                                                                                                                                                  |
|----|-------------------------------------------------------------------|-------------------------------------------------------------------------------|---------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                                                                   |                                                                               | Захід захисту | Налаштований зміст заходу захисту                                                                                                                                                                                                |
| 11 | Пов'язання атрибутів авторизованими особами                       | Параметр: binding_by_authorized_individuals<br>Тип: boolean<br>Значення: true | АС-16(4)      | Тільки уповноважені особи (з відповідними атрибутами безпеки) можуть створювати або делегувати повноваження (наприклад, призначати ролі 'assistant' або 'delegate' в моделі 'subject_employee').                                 |
| 12 | Відображення атрибутів на пристроях виведення (nitro)             | Параметр: display_attributes<br>Тип: boolean<br>Значення: true                | АС-16(5)      | Завдяки інтеграції з 'synrc/nitro', рівні конфіденційності та безпекові атрибути об'єктів чітко рендеряться на інтерфейсі клієнта (веб-сторінках) у вигляді візуальних міток.                                                    |
| 13 | Підтримка пов'язання атрибутів організацією (org, branch)         | Параметр: org_binding_support<br>Тип: boolean<br>Значення: true               | АС-16(6)      | В 'subject_employee' підтримуються специфічні атрибути для ієрархічної структури (поля 'org', 'branch'), що дозволяє обчислювати доступ на основі приналежності до організаційної одиниці.                                       |
| 14 | Послідовна інтерпретація атрибутів (XACML algorithms)             | Параметр: consistent_interpretation<br>Тип: boolean<br>Значення: true         | АС-16(7)      | Використання стандартизованих алгоритмів комбінування політик XACML (алгоритми 'all' або 'any') у PDP гарантує строгу та несуперечливу математичну інтерпретацію безпекових обмежень по всій системі.                            |
| 15 | Техніки та технології пов'язання атрибутів (Pattern Matching, CA) | Параметр: binding_techniques<br>Тип: boolean<br>Значення: true                | АС-16(8)      | Механізми Pattern Matching платформи Erlang/OTP використовуються для швидкого та безпомилкового порівняння атрибутів. Інтеграція криптографічних підписів ('synrc/ca') у структуру об'єкта підтверджує автентичність його міток. |
| 16 | Перепризначення атрибутів згідно з життєвим циклом                | Параметр: attribute_reassignment<br>Тип: boolean<br>Значення: true            | АС-16(9)      | Політики можуть передбачати логіку перепризначення атрибутів у процесі життєвого циклу об'єкта (наприклад, після підписання документа його атрибут статусу змінюється, що автоматично змінює правила доступу до нього).          |
| 17 | Конфігурація атрибутів уповноваженими особами (PAP API)           | Параметр: authorized_configuration<br>Тип: boolean<br>Значення: true          | АС-16(10)     | Інфраструктура PAP надає API для гнучкого налаштування нових типів атрибутів і політик, гарантуючи, що ці налаштування виконуються тільки згідно встановлених процедур адміністрування.                                          |
| 18 | Атрибути безпеки об'єкту                                          | Параметр: object_security_attributes<br>Тип: boolean<br>Значення: true        | АС-4(1)       | ВРЕ перед будь-яким переходом до наступного кроку ('bpe:next') аналізує атрибути (метадані, документи), прив'язані до процесу. Шлюзи перевіряють ці мітки для ухвалення рішень маршрутизації.                                    |
| 19 | Домени обробки (ізолювані процеси Erlang)                         | Параметр: processing_domains<br>Тип: boolean<br>Значення: true                | АС-4(2)       | Кожен BPMN-процес виконується як окремий ізолюваний процес віртуальної машини Erlang (Actor). Ці процеси створюють незалежні безпекові домени обробки інформації без спільної пам'яті.                                           |
| 20 | Управління інформаційним потоком (SequenceFlow)                   | Параметр: enforce_sequence_flow<br>Тип: boolean<br>Значення: true             | АС-4(3)       | Сутність 'sequenceFlow' (ребра графу BPMN) математично обмежує єдині можливі шляхи передачі інформації між задачами.                                                                                                             |
| 21 | Управління потоком зашифрованої інформації                        | Параметр: encrypted_payloads<br>Тип: boolean<br>Значення: true                | АС-4(4)       | ВРЕ здатний маршрутизувати зашифровані payload-дані як непрозорі (opaque) структури, залишаючи розшифрування авторизованим клієнтам або конкретним сервісним завданням ('serviceTask').                                          |

| №  | Вимога з безпеки інформації                                    | Вимога ГПБ                                                                  | ЦПБ           |                                                                                                                                                                                    |
|----|----------------------------------------------------------------|-----------------------------------------------------------------------------|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                                                                |                                                                             | Захід захисту | Налаштований зміст заходу захисту                                                                                                                                                  |
| 22 | Вбудовування типів даних (Erlang Records)                      | Параметр: embedded_data_types<br>Тип: boolean<br>Значення: true             | АС-4(5)       | Об'єкти інформаційного потоку строго типізовані через структури 'record' (наприклад, '#userTask{}', '#messageEvent{}'). Це запобігає переміщенню невідомих форматів.               |
| 23 | Метадані (список docs у BPE)                                   | Параметр: metadata_management<br>Тип: boolean<br>Значення: true             | АС-4(6)       | BPE керує метаданими документів, використовуючи внутрішній список 'docs' (API 'bpe:docs/1', 'bpe:amend/2'), що невіддільно супроводжує потік процесу.                              |
| 24 | Механізми одностороннього потоку (DAG)                         | Параметр: one_way_flow<br>Тип: boolean<br>Значення: true                    | АС-4(7)       | Направлені ациклічні графи (DAG) BPMN природно реалізують односторонню передачу даних від 'beginEvent' до 'endEvent' без можливості повернення (якщо це не передбачено схемою).    |
| 25 | Політики безпеки (Gateways)                                    | Параметр: security_policies<br>Тип: boolean<br>Значення: true               | АС-4(8)       | Логічні шлюзи ('gateway') виступають інтегрованими фільтрами, які застосовують політики безпеки на розгалуженнях потоку.                                                           |
| 26 | Перевірки, що проводить персонал (UserTask)                    | Параметр: personnel_checks<br>Тип: boolean<br>Значення: true                | АС-4(9)       | Використання '#userTask{}' зупиняє автоматичний потік інформації та вимагає ручної перевірки (Human-in-the-loop) і підтвердження для продовження маршруту.                         |
| 27 | Активізація та деактивізація фільтрів політики (BoundaryEvent) | Параметр: filter_activation<br>Тип: boolean<br>Значення: true               | АС-4(10)      | Використання подій, як-от 'boundaryEvent' (Boundary Events), дозволяє динамічно активувати обхідні гілки політик в залежності від виникнення інцидентів або таймаутів.             |
| 28 | Конфігурація фільтрів політики безпеки (XML)                   | Параметр: filter_configuration<br>Тип: boolean<br>Значення: true            | АС-4(11)      | Правила маршрутизації (фільтри) завантажуються декларативно з BPMN XML файлів та транслуються у незмінні правила Erlang ('bpe:load/1').                                            |
| 29 | Ідентифікатори типу даних (MessageEvent)                       | Параметр: data_type_identifiers<br>Тип: boolean<br>Значення: true           | АС-4(12)      | Система розрізняє вхідні повідомлення через обробку 'messageEvent' з відповідними ідентифікаторами повідомлень, ігноруючи нерозпізнані сигнали.                                    |
| 30 | Декомпозиція на субкомпоненти (Call Activity)                  | Параметр: subcomponent_decomposition<br>Тип: boolean<br>Значення: true      | АС-4(13)      | BPE підтримує виклик підпроцесів ('Call Activity'), що дозволяє розбити складні потоки на ізольовані субкомпоненти зі своїми власними політиками.                                  |
| 31 | Обмеження фільтра політики (conditions)                        | Параметр: policy_filter_constraints<br>Тип: boolean<br>Значення: true       | АС-4(14)      | Можливості маршрутизації обмежені набором умов 'condition()', які дозволяють математично гарантувати неперетин потоків.                                                            |
| 32 | Виявлення несанкціонованої інформації                          | Параметр: unauthorized_info_detection<br>Тип: boolean<br>Значення: true     | АС-4(15)      | При спробі передати процесу повідомлення, яке не відповідає поточній стадії потоку (unauthorized message), система автоматично відкидає його або фіксує в лог як невалідний event. |
| 33 | Передача інформації про взаємопов'язані системи (ServiceTask)  | Параметр: interconnected_systems_transfer<br>Тип: boolean<br>Значення: true | АС-4(16)      | Компонент '#serviceTask{}' дозволяє інтегрувати механізми перевірки даних, перш ніж передати інформаційний потік до інших ІТС (наприклад, через API REST або RPC).                 |
| 34 | Прив'язка атрибуту безпеки (Process ID)                        | Параметр: security_attribute_binding<br>Тип: boolean<br>Значення: true      | АС-4(18)      | Інформація в рамках потоку жорстко прив'язується до Process ID (Id інстанції). Усі документи успадковують обмеження доступу поточного процесу.                                     |

| №  | Вимога з безпеки інформації                                       | Вимога ГПБ                                                              | ЦПБ           |                                                                                                                                                                                      |
|----|-------------------------------------------------------------------|-------------------------------------------------------------------------|---------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                                                                   |                                                                         | Захід захисту | Налаштований зміст заходу захисту                                                                                                                                                    |
| 35 | Перевірка метаданих (BPMN compare)                                | Параметр: metadata_validation<br>Тип: boolean<br>Значення: true         | АС-4(19)      | BPMN-умови підтримують функції типу '{compare, Field, ConstCheckAgainst}', що перевіряють значення конкретних метаданих об'єкта під час прийняття рішення про маршрут.               |
| 36 | Затверджені рішення (Default-Deny)                                | Параметр: approved_decisions<br>Тип: boolean<br>Значення: true          | АС-4(20)      | Erlang Match Specifications та XACML гарантують, що лише явно затверджені алгоритми маршрутизації виконуються (Default-Deny принцип).                                                |
| 37 | Фізичне та логічне відділення інформаційних потоків               | Параметр: physical_logical_separation<br>Тип: boolean<br>Значення: true | АС-4(21)      | Логічне відділення гарантується механізмом процесів OTP VM. Можливість виконання різних процесів на різних фізичних нодах Erlang-кластера забезпечує фізичне відділення потоків.     |
| 38 | Єдиний доступ (bpe:next)                                          | Параметр: single_access_point<br>Тип: boolean<br>Значення: true         | АС-4(22)      | Централізований компонент контролю 'bpe:next' слугує єдиною точкою (Choke Point) доступу та маршрутизації для всіх інформаційних потоків.                                            |
| 39 | Модифікована інформація, яка не підлягає оприлюдненню (scrubbing) | Параметр: scrub_hidden_fields<br>Тип: boolean<br>Значення: true         | АС-4(23)      | При поверненні історії та статусів через API клієнту, BPE може відфільтровувати та очищати внутрішні атрибути ('scrubbing'), не допускаючи витoku чутливої інформації.               |
| 40 | Нормалізований формат (BPE Record)                                | Параметр: normalized_format<br>Тип: boolean<br>Значення: true           | АС-4(24)      | Весь внутрішній потік конвертується в уніфікований стандартизований формат ('BPE Record Format'), незалежно від того, як дані надійшли на вхід.                                      |
| 41 | Очищення даних (Garbage Collection, End Event)                    | Параметр: data_sanitization<br>Тип: boolean<br>Значення: true           | АС-4(25)      | Вбудовані механізми Garbage Collection віртуальної машини Erlang та знищення об'єктів пам'яті ізольованого процесу після завершення ('End Event') забезпечують очищення даних з ОЗУ. |
| 42 | Дії з фільтрації аудиту (hist у KVS)                              | Параметр: audit_filter_actions<br>Тип: boolean<br>Значення: true        | АС-4(26)      | Кожен крок і зміна маршруту фіксується у вигляді об'єкта 'hist' у 'kvs', створюючи прозорий ланцюг подій, де шлюзи та фільтри залишають свій слід.                                   |
| 43 | Незалежні фільтруючі механізми (ABAC + BPE)                       | Параметр: independent_filtering<br>Тип: boolean<br>Значення: true       | АС-4(27)      | Дозвіл на доступ (ABAC) та перевірка логіки процесу (BPE) працюють як архітектурно незалежні механізми, підсилюючи концепцію "Defense-in-depth".                                     |
| 44 | Лінійні фільтрувальні канали (Linear Pipeline)                    | Параметр: linear_pipelines<br>Тип: boolean<br>Значення: true            | АС-4(28)      | BPE підтримує лінійну маршрутизацію (Linear Pipeline), коли 'SequenceFlow' гарантовано не має відгалужень, забезпечуючи послідовне виконання політик без ризику обходу.              |
| 45 | Механізми оркестровки                                             | Параметр: orchestration_mechanisms<br>Тип: boolean<br>Значення: true    | АС-4(29)      | Ядро BPE виступає єдиним централізованим механізмом оркестровки інформаційного обміну в рамках системи.                                                                              |
| 46 | Фільтрація з використанням кількох процесів (Parallel Gateway)    | Параметр: multi_process_filtering<br>Тип: boolean<br>Значення: true     | АС-4(30)      | Компонент 'Parallel Gateway' ('#gateway{type=parallel}') створює декілька паралельних потоків, кожен з яких може мати власні незалежні правила фільтрації.                           |
| 47 | Запобігання передачі вмісту                                       | Параметр: content_transfer_prevention<br>Тип: boolean<br>Значення: true | АС-4(31)      | Якщо інформаційний об'єкт не відповідає політиці (фільтр на Gateway відхилив вміст), процес переривається або спрямовується на подію помилки (Error Event).                          |

| №                                                   | Вимога з безпеки інформації                                      | Вимога ГПБ                                                                | ЦПБ           |                                                                                                                                                                                                                                                  |
|-----------------------------------------------------|------------------------------------------------------------------|---------------------------------------------------------------------------|---------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                     |                                                                  |                                                                           | Захід захисту | Налаштований зміст заходу захисту                                                                                                                                                                                                                |
| 48                                                  | Вимоги до процесу передачі інформації (Receive/Send Task)        | Параметр: transfer_process_requirements<br>Тип: boolean<br>Значення: true | AC-4(32)      | Механізми 'Receive Task' та 'Send Task' строго декларують вимоги до структури payload-повідомлень перед тим, як дозволити зовнішній чи внутрішній обмін.                                                                                         |
| <b>2. ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (IA) (IA)</b> |                                                                  |                                                                           |               |                                                                                                                                                                                                                                                  |
| 49                                                  | Ідентифікація та автентифікація (організаційні користувачі)      | Параметр: org_user_auth<br>Тип: boolean<br>Значення: true                 | IA-2          | Система однозначно ідентифікує та автентифікує (перевіряє справжність) організаційних користувачів та процеси, що діють від їх імені, перед тим, як дозволити їм доступ до захищених ресурсів.                                                   |
| 50                                                  | Ідентифікація та автентифікація (неорганізаційні користувачі)    | Параметр: non_org_user_auth<br>Тип: boolean<br>Значення: true             | IA-8          | Зовнішні користувачі, що підключаються з публічних мереж, проходять сувору автентифікацію (наприклад, за допомогою mTLS або інтеграції з КЕП) для запобігання анонівному або підробленому доступу.                                               |
| 51                                                  | Автентифікація на основі пароля (хешування)                      | Параметр: password_based_auth<br>Тип: boolean<br>Значення: true           | IA-5(1)       | Для паролів чи PING-кодів (наприклад, для розблокування контейнерів PKCS#12) використовуються криптостійкі функції хешування з сіллю для запобігання атакам.                                                                                     |
| 52                                                  | Автентифікація на основі відкритого ключа                        | Параметр: pki_enabled<br>Тип: boolean<br>Значення: true                   | IA-5(2)       | Є основним профілем бібліотеки 'ca'. Вона генерує, перевіряє (validate) та керує життєвим циклом інфраструктури відкритих ключів (X.509), забезпечуючи строгу автентифікацію.                                                                    |
| 53                                                  | Зміна автентифікаторів до доставки (CSR)                         | Параметр: pre_delivery_change<br>Тип: boolean<br>Значення: true           | IA-5(5)       | Система підтримує протоколи, за яких приватний ключ генерується на пристрої клієнта, а до CA відправляється лише Certificate Signing Request (CSR). Це гарантує зміну/встановлення ключів ще до факту доставки готового сертифіката користувачу. |
| 54                                                  | Захист автентифікаторів (PEM/PKCS#12)                            | Параметр: authenticator_protection<br>Тип: boolean<br>Значення: true      | IA-5(6)       | Приватні ключі (автентифікатори) зберігаються в захищеному зашифрованому вигляді (наприклад, контейнери формату PEM з паролем або PKCS#12), що унеможливорює використання ключів без знання пароля доступу.                                      |
| 55                                                  | Відсутність вбудованих незашифрованих статичних автентифікаторів | Параметр: no_unencrypted_static<br>Тип: boolean<br>Значення: true         | IA-5(7)       | Бібліотека заохочує динамічну генерацію ключів під час ініціалізації середовища (Root CA), що виключає необхідність зберігання "hardcoded" секретів у вихідному коді системи.                                                                    |
| 56                                                  | Багатосистемні облікові записи (mTLS/SSO)                        | Параметр: multi_system_accounts<br>Тип: boolean<br>Значення: true         | IA-5(8)       | Сертифікати X.509, видані 'sync/ca', можуть використовуватись як багатосистемний засіб автентифікації (на кшталт mTLS/SSO) для доступу до різноманітних мікросервісів та ERP-компонентів, розгорнутих у спільному домені довіри.                 |
| 57                                                  | Управління об'єднанням автентифікаторів (Intermediate CA)        | Параметр: federation_management<br>Тип: boolean<br>Значення: true         | IA-5(9)       | Підтримується архітектура федерації ключів (Federation) за рахунок використання ланцюгів сертифікатів (Intermediate CAs) та можливості перевіряти крос-сертифікаційні підписи (Cross-Certification).                                             |
| 58                                                  | Динамічне зв'язування мандатів                                   | Параметр: dynamic_credential_binding<br>Тип: boolean<br>Значення: true    | IA-5(10)      | Бібліотека дозволяє видавати короткострокові сертифікати, що динамічно зв'язуються з конкретною сесією, IP-адресою чи атрибутами користувача (Dynamic Credential Binding).                                                                       |

| №                                  | Вимога з безпеки інформації                                             | Вимога ГПБ                                                           | ЦПБ           |                                                                                                                                                                                                                                                                                 |
|------------------------------------|-------------------------------------------------------------------------|----------------------------------------------------------------------|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                    |                                                                         |                                                                      | Захід захисту | Налаштований зміст заходу захисту                                                                                                                                                                                                                                               |
| 59                                 | Автентифікація на основі апаратних токенів                              | Параметр: hardware_token_auth<br>Тип: boolean<br>Значення: true      | IA-5(11)      | 'synrc/ca' прозоро підтримує роботу з підписами, згенерованими на апаратних захищених носіях (Hardware Tokens, НКИ, e-Токени, PKCS#11). Серверній частині потрібен лише відкритий ключ для валідації.                                                                           |
| 60                                 | Ефективність біометричної автентифікації (Secure Enclave)               | Параметр: biometric_efficiency<br>Тип: boolean<br>Значення: true     | IA-5(12)      | Хоча 'sa' працює з криптографією, будь-яка біометрична автентифікація (наприклад, TouchID, FaceID) на клієнті конвертується в криптографічний підпис (наприклад, через Secure Enclave), який успішно валідується модулями 'synrc/ca'.                                           |
| 61                                 | Закінчення терміну дії автентифікаторів (NotBefore/NotAfter)            | Параметр: authenticator_expiration<br>Тип: boolean<br>Значення: true | IA-5(13)      | Жорстко перевіряються поля 'NotBefore' та 'NotAfter' в сертифікатах X.509. Сертифікати зі строком дії, що минув, автоматично відхиляються без можливості оскарження.                                                                                                            |
| 62                                 | Управління змістом довірчих сховищ (Trust Stores)                       | Параметр: trust_store_management<br>Тип: boolean<br>Значення: true   | IA-5(14)      | На рівні сервера бібліотека керує сховищем довірених кореневих сертифікатів (Trust Store, 'priv/cacerts'). Оновлення або відкликання (через CRL) довіри до Root CA автоматично реплікується на політику доступу.                                                                |
| 63                                 | Продукти та послуги, затверджені уповноваженим органом (ДСТУ 4145-2002) | Параметр: approved_products<br>Тип: boolean<br>Значення: true        | IA-5(15)      | Завдяки абстракції криптографічних примітивів, 'synrc/ca' підтримує державні криптографічні стандарти (наприклад, алгоритм цифрового підпису ДСТУ 4145-2002), необхідні для побудови систем, затверджених Державною службою спеціального зв'язку та захисту інформації (ДССЗІ). |
| 64                                 | Передача довірчої автентифікації зовнішньої сторони (АЦСК)              | Параметр: external_auth_transfer<br>Тип: boolean<br>Значення: true   | IA-5(16)      | 'synrc/ca' здатна перевіряти підписи, накладені зовнішніми Акредитованими центрами сертифікації ключів (АЦСК), забезпечуючи довірчу автентифікацію зовнішніх сторін.                                                                                                            |
| 65                                 | Менеджер паролів (KeyStores)                                            | Параметр: password_manager<br>Тип: boolean<br>Значення: true         | IA-5(18)      | Незважаючи на те, що 'synrc/ca' не є менеджером паролів у звичному розумінні, механізми захисту ключів (KeyStores, PKCS#12) виступають у ролі захищених криптографічних сейфів, які можна відкрити лише спеціалізованими засобами із дотриманням секретності.                   |
| 3. АУДИТ ТА ПІДЗВІТНІСТЬ (AU) (AU) |                                                                         |                                                                      |               |                                                                                                                                                                                                                                                                                 |
| 66                                 | Узагальнення записів про аудит з декількох джерел (feeds)               | Параметр: audit_aggregation<br>Тип: boolean<br>Значення: true        | AU-2(1)       | BPMN підтримує паралельні ланцюги (feeds, streams), що дозволяє агрегувати записи про аудит з декількох джерел у єдиний потік журналу.                                                                                                                                          |
| 67                                 | Перегляд та оновлення (індексація hist)                                 | Параметр: audit_review_update<br>Тип: boolean<br>Значення: true      | AU-2(3)       | Записи аудиту періодично індексуються, що дозволяє швидко витягувати всю історію (наприклад, через 'bpe:hist/1').                                                                                                                                                               |
| 68                                 | Зміст записів аудиту (метадані, Permit/Deny)                            | Параметр: audit_content_metadata<br>Тип: boolean<br>Значення: true   | AU-3          | Інформація в логах BPMN (особливо при збереженні об'єктів ВРЕ/АВАС) містить вичерпні метадані: тип події, суб'єкт, цільовий об'єкт, результат операції (Permit/Deny) та позначку часу, що повністю закриває вимоги AU-3.                                                        |

| №                                             | Вимога з безпеки інформації                              | Вимога ГПБ                                                              | ЦПБ           |                                                                                                                                                                                                                                                                                                                  |
|-----------------------------------------------|----------------------------------------------------------|-------------------------------------------------------------------------|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                               |                                                          |                                                                         | Захід захисту | Налаштований зміст заходу захисту                                                                                                                                                                                                                                                                                |
| 69                                            | Місткість сховища записів аудиту (розподілені бекенди)   | Параметр: audit_storage_capacity<br>Тип: boolean<br>Значення: true      | AU-4          | BPMN може використовувати розподілені бекенди (Riak KV, розподілена Mnesia, KAI), що дозволяє горизонтально масштабувати місткість сховища логів (AU-4) без зупинки системи.                                                                                                                                     |
| 70                                            | Позначка часу (erlang:system_time)                       | Параметр: sync_time_source<br>Тип: boolean<br>Значення: true            | AU-8(1)       | Усі ідентифікатори та події, що генеруються в BPMN (наприклад, через генератор 'id_seq'), прив'язані до високоточного системного часу Erlang ('erlang:system_time/1'). Це забезпечує надійну прив'язку подій до точного часу (AU-8(1)).                                                                          |
| 71                                            | Апаратні носії одноразового запису (Append-Only)         | Параметр: append_only_enforced<br>Тип: boolean<br>Значення: true        | AU-9(1)       | Архітектура Append-Only гарантує, що записи не оновлюються (по UPDATE). Це створює ефект апаратного "Write-Once-Read-Many" (AU-9(1)). Видалити запис без порушення криптографічної чи логічної цілісності ланцюга посилань практично неможливо.                                                                  |
| 72                                            | Неспровтовність (Ланцюжок збереження доказів)            | Параметр: non_repudiation<br>Тип: boolean<br>Значення: true             | AU-10(3)      | Журнали BPMN слугують доказовою базою (Ланцюжок збереження доказів AU-10(3)). У комбінації з 'sync/ca' записи можуть підписуватися ЕЦП (AU-10(5)), що гарантує 100% неспровтовність дій автора транзакції.                                                                                                       |
| 73                                            | Довгострокова можливість отримання записів аудиту        | Параметр: log_retention_days<br>Тип: integer<br>Значення: 1825          | AU-11(1)      | Сховища типу RocksDB (в якості бекенда BPMN) оптимізовані для довгострокового зберігання петабайтів даних (Long-Term Storage) із забезпеченням швидкого доступу до історичних записів (AU-11(1)).                                                                                                                |
| 74                                            | Огляд, аналіз та звітність про аудит                     | Параметр: audit_analysis_tools<br>Тип: boolean<br>Значення: true        | AU-6          | Аналіз аудиту відбувається за допомогою консольних інструментів платформи (наприклад, 'kvs:hist/1' або інтерфейсів Erlang Shell). Також доступний експорт журналів для SIEM.                                                                                                                                     |
| 75                                            | Генерація аудиту                                         | Параметр: audit_generation<br>Тип: boolean<br>Значення: true            | AU-12         | KVS забезпечує генерацію записів аудиту для всіх операцій створення, оновлення (через створення нової ревізії) та видалення, гарантуючи фіксацію критичних подій безпеки.                                                                                                                                        |
| 4. ЦІЛІСНІСТЬ СИСТЕМИ ТА ІНФОРМАЦІЇ (SI) (SI) |                                                          |                                                                         |               |                                                                                                                                                                                                                                                                                                                  |
| 76                                            | Перевірка вводу перевизначення (лише серверна валідація) | Параметр: server_side_validation_only<br>Тип: boolean<br>Значення: true | SI-10(1)      | Клієнтська сторона (браузер) в 'sync/nitro' не містить логіки валідації, яку можна було б обійти чи перевизначити (override) через маніпуляції з DOM або JS. Уся перевірка жорстко зашита у виконуваний код Erlang ('sync/form'). Жодне клієнтське перевизначення не здатне змінити правила серверної валідації. |
| 77                                            | Перевірка вводу інформації помилок (екранування HTML)    | Параметр: escape_html_output<br>Тип: boolean<br>Значення: true          | SI-10(2)      | Повідомлення про помилки валідації генеруються на сервері (Erlang) і передаються клієнту через WebSocket як готові безпечні HTML-фрагменти (екрановані 'nitro'), запобігаючи виникненню XSS під час відображення помилкового вводу користувачу.                                                                  |



| №                                     | Вимога з безпеки інформації                        | Вимога ГПБ                                                          | ЦПБ           |                                                                                                                                                                                                                                                                                                                                                      |
|---------------------------------------|----------------------------------------------------|---------------------------------------------------------------------|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                       |                                                    |                                                                     | Захід захисту | Налаштований зміст заходу захисту                                                                                                                                                                                                                                                                                                                    |
| 78                                    | Передбачувана поведінка (декларативні Records)     | Параметр: predictable_behavior<br>Тип: boolean<br>Значення: true    | SI-10(3)      | Оскільки валідація описана декларативно (Record-структурами з типами полів, як-от 'integer', 'string', 'date'), реакція системи на некоректні дані завжди є 100% передбачуваною (Predictable Behavior). Відсутні приховані клієнтські скрипти, що можуть реагувати непередбачувано на специфічний ввід.                                              |
| 79                                    | Часові взаємодії (таймаути N2O)                    | Параметр: timing_interactions<br>Тип: boolean<br>Значення: true     | SI-10(4)      | Оскільки ввід передається через сталий WebSocket-зв'язок (N2O), система має вбудований контроль тайм-аутів з'єднання та захист від перевантажень (Rate-limiting). Довгі запити або неповний ввід просто ігноруються після завершення вікна сесії, блокуючи атаки типу Slowloris.                                                                     |
| 80                                    | Обмеження вводу довіреними джерелами і форматами   | Параметр: strict_type_checking<br>Тип: boolean<br>Значення: true    | SI-10(5)      | Бібліотека 'form' пропускає дані лише для тих полів, які явно задекларовані в схемі форми (Approved Formats). Pattern Matching платформи Erlang автоматично відкидає будь-які JSON/BERT payload-пакети, які містять незадекларовані поля (унеможлижуючи Mass Assignment Vulnerability) або походять з неавторизованого джерела (Trust Zone).         |
| 81                                    | Профілактика вводу даних (блокування через АВАС)   | Параметр: data_input_prevention<br>Тип: boolean<br>Значення: true   | SI-10(6)      | Комбінація 'nitro' та 'abac' дозволяє здійснювати профілактику (Prevention): якщо користувач не має права вносити дані в певне поле, це поле взагалі не рендериться на стороні клієнта або рендериться в стані 'readonly/disabled', а бекенд-валідатор автоматично блокує будь-яку спробу його програмно передати (Data Input Prevention at source). |
| 5. ЗАХИСТ НОСІЇВ ІНФОРМАЦІЇ (MP) (MP) |                                                    |                                                                     |               |                                                                                                                                                                                                                                                                                                                                                      |
| 82                                    | Доступ до носіїв інформації (через Erlang VM)      | Параметр: os_level_access_control<br>Тип: boolean<br>Значення: true | MP-2(1)       | Прямий доступ до файлів БД (RocksDB/Mnesia) на носіях закритий на рівні ОС. Весь логічний доступ здійснюється виключно через інтерфейс KVS всередині віртуальної машини Erlang, яка діє як обмежений шлюз доступу (MP-2(1)).                                                                                                                         |
| 83                                    | Криптографічний захист носіїв (Data-at-Rest)       | Параметр: encryption_at_rest<br>Тип: boolean<br>Значення: true      | MP-4(1)       | KVS підтримує політики постійного збереження даних на диск (Disk Persistence). Захист інформації в стані спокою (Data-at-Rest) реалізується через інтеграцію з шифруванням файлової системи (LUKS) або шифруванням значень (MP-4(1)).                                                                                                                |
| 84                                    | Транспортування носіїв інформації (TLS-реплікація) | Параметр: tls_replication<br>Тип: boolean<br>Значення: true         | MP-5(1)       | В розподіленому кластері KVS реплікує дані (переміщує їх) між нодами. Цей процес транспортування інформації захищається за допомогою TLS (Erlang Distribution over TLS), запобігаючи перехопленню даних поза контрольованими зонами (MP-5(1), MP-5(4)).                                                                                              |

| №                                         | Вимога з безпеки інформації                            | Вимога ГПБ                                                               | ЦПБ           |                                                                                                                                                                                                                                                                                                                                                                      |
|-------------------------------------------|--------------------------------------------------------|--------------------------------------------------------------------------|---------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                           |                                                        |                                                                          | Захід захисту | Налаштований зміст заходу захисту                                                                                                                                                                                                                                                                                                                                    |
| 85                                        | Знищення інформації на носіях (Tombstones)             | Параметр: tombstone_deletion_enabled<br>Тип: boolean<br>Значення: true   | MP-6(8)       | Хоча KVS є системою Append-Only, він надає чіткі API ('kvs:delete') для виконання процедур очищення даних (наприклад, для забезпечення вимог GDPR "Право на забуття"). Під час видалення запису, бекенд RocksDB гарантовано помічає блоки як видалені (Tombstones), які під час подальшої компресії фізично стираються з носія без можливості відновлення (MP-6(8)). |
| 86                                        | Використання носіїв інформації (марковані томи)        | Параметр: authorized_volumes_only<br>Тип: boolean<br>Значення: true      | MP-7(1)       | KVS може конфігуруватись на використання виключно заздалегідь визначених (іменованих) просторів таблиць на авторизованих томах зберігання, забороняючи використання невідомих чи немаркованих баз даних (MP-7(1)).                                                                                                                                                   |
| 6. ЗАХИСТ СИСТЕМ ТА КОМУНІКАЦІЙ (SC) (SC) |                                                        |                                                                          |               |                                                                                                                                                                                                                                                                                                                                                                      |
| 87                                        | Ізоляція функції безпеки                               | Параметр: security_function_isolation<br>Тип: boolean<br>Значення: true  | SC-2          | Функції безпеки (шифрування, авторизація) виконуються в ізольованих процесах Erlang VM, окремо від бізнес-логіки системи. Ця архітектура Actor Model унеможливає втручання несанкціонованих процесів у роботу механізмів безпеки.                                                                                                                                    |
| 88                                        | Інформація в загальних ресурсах системи                | Параметр: shared_resource_protection<br>Тип: boolean<br>Значення: true   | SC-4          | Erlang VM не використовує спільну пам'ять (shared memory) між процесами сесій N2O. Пам'ять звільняється автоматично (Garbage Collection) після обробки запиту, запобігаючи витоків залишкової інформації між різними користувачами.                                                                                                                                  |
| 89                                        | Захист від атак «відмова в обслуговуванні» (DoS)       | Параметр: dos_protection<br>Тип: boolean<br>Значення: true               | SC-5          | Інфраструктура N2O/Cowboy обробляє сотні тисяч конкурентних WebSocket-з'єднань завдяки легкості Erlang-процесів. Вбудовані механізми rate-limiting, обмеження розміру payload та таймаути захищають від атак на виснаження ресурсів (Slowloris, Flood).                                                                                                              |
| 90                                        | Захист периметра (Boundary Protection)                 | Параметр: boundary_protection<br>Тип: boolean<br>Значення: true          | SC-7          | Всі зовнішні підключення приймаються виключно через єдиний порт (керований інтерфейс), що обробляється веб-сервером (Cowboy). Доступ до внутрішніх API і вузлів кластера блокується правилами мережевого екранування за замовчуванням (Default Deny).                                                                                                                |
| 91                                        | Захист цілісності та конфіденційності під час передачі | Параметр: transmission_confidentiality<br>Тип: boolean<br>Значення: true | SC-8          | Передача інформації між клієнтом і сервером здійснюється виключно через зашифровані канали (WSS/TLS), що унеможливає перехоплення (Man-in-the-Middle) або несанкціоновану модифікацію даних на льоту.                                                                                                                                                                |
| 92                                        | Розрив мережевого з'єднання                            | Параметр: network_disconnect_timeout<br>Тип: integer<br>Значення: 3600   | SC-10         | Протокол N2O автоматично розриває мережеве з'єднання після завершення комунікаційного сеансу або перевищення часу очікування (Inactivity Timeout), звільняючи ресурси та сесію.                                                                                                                                                                                      |
| 93                                        | Криптографічне управління ключами                      | Параметр: cryptographic_key_management<br>Тип: boolean<br>Значення: true | SC-12         | Керування ключами та сертифікатами для встановлення захищених з'єднань делегується бібліотеці 'sync/ca' та інтегрованим механізмам TLS ОС, що відповідають чинним криптографічним стандартам.                                                                                                                                                                        |

| №                                           | Вимога з безпеки інформації                   | Вимога ГПБ                                                               | ЦПБ           |                                                                                                                                                                                                                                      |
|---------------------------------------------|-----------------------------------------------|--------------------------------------------------------------------------|---------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                             |                                               |                                                                          | Захід захисту | Налаштований зміст заходу захисту                                                                                                                                                                                                    |
| 94                                          | Криптографічний захист                        | Параметр: cryptographic_protection<br>Тип: boolean<br>Значення: true     | SC-13         | Система підтримує використання схвалених криптографічних алгоритмів (AES-GCM, SHA-256/512, ДСТУ 4145-2002 через відповідні модулі), які забезпечують необхідний рівень стійкості.                                                    |
| 95                                          | Автентичність сеансу зв'язку                  | Параметр: session_authenticity<br>Тип: boolean<br>Значення: true         | SC-23         | Автентичність WebSocket-сесій N2O захищається токенами з криптографічним підписом (HMAC). Це гарантує, що повідомлення в рамках сесії не можуть бути підроблені або інжектвані сторонньою особою.                                    |
| 7. УПРАВЛІННЯ КОНФІГУРАЦІЄЮ (CM) (CM)       |                                               |                                                                          |               |                                                                                                                                                                                                                                      |
| 96                                          | Базова конфігурація (Baseline Configuration)  | Параметр: baseline_configuration_code<br>Тип: boolean<br>Значення: true  | CM-2          | Файл 'erpuno.ex' фіксує єдину базову конфігурацію (Baseline) безпеки для всієї системи. Зміни в конфігурації застосовуються виключно через оновлення коду, що забезпечує строгий контроль та аудит змін.                             |
| 97                                          | Контроль змін конфігурації                    | Параметр: configuration_change_control<br>Тип: boolean<br>Значення: true | CM-3          | Оскільки CMDB є частиною вихідного коду (Elixir модуль), всі зміни проходять через стандартний процес розробки (Code Review, CI/CD, контроль версій Git), унеможливаючи несанкціоноване втручання в налаштування на "живій" системі. |
| 98                                          | Налаштування конфігурації                     | Параметр: compile_time_config<br>Тип: boolean<br>Значення: true          | CM-6          | Параметри політик безпеки та їхні значення за замовчуванням жорстко зашиті в 'erpuno.ex'. Компілятор генерує незмінний об'єктний файл, який гарантує виконання затверджених налаштувань під час роботи.                              |
| 99                                          | Інвентаризація компонентів ІТС                | Параметр: component_inventory<br>Тип: boolean<br>Значення: true          | CM-8          | Профіль автоматично фіксує перелік використовуваних компонентів системи (бібліотеки 'sync/kvs', 'sync/ca' тощо) та їхні параметри, забезпечуючи інтегральну інвентаризацію модулів захисту.                                          |
| 100                                         | План управління конфігурацією                 | Параметр: auto_generate_documentation<br>Тип: boolean<br>Значення: true  | CM-9          | Профіль 'ERPUNO.Profile' слугує самодокументованим планом управління конфігураціями, здатним автоматично генерувати актуальну документацію (через метод 'generate_md/0').                                                            |
| 8. ПЛАНУВАННЯ БЕЗПЕРЕРВНОЇ РОБОТИ (CP) (CP) |                                               |                                                                          |               |                                                                                                                                                                                                                                      |
| 101                                         | Резервне копіювання інформаційної системи     | Параметр: system_backup<br>Тип: boolean<br>Значення: true                | CP-9          | Система здійснює автоматичне створення резервних копій бази даних KVS. Бекапи можуть зберігатися локально або відправлятися до хмарних сховищ, гарантуючи відновлення даних відповідно до RTO/RPO.                                   |
| 102                                         | Відновлення інформаційної системи             | Параметр: system_recovery<br>Тип: boolean<br>Значення: true              | CP-10         | KVS забезпечує механізми швидкого відновлення з резервних копій ('kvs:restore/1'), дозволяючи адміністраторам відновити працездатність вузла з гарантією логічної цілісності журналу транзакцій.                                     |
| 9. РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR) (IR)        |                                               |                                                                          |               |                                                                                                                                                                                                                                      |
| 103                                         | Політика та процедури реагування на інциденти | Параметр: incident_policy_enforcement<br>Тип: boolean<br>Значення: true  | IR-1          | Політика реагування на інциденти закріплена безпосередньо у бізнес-процесах (BPMN) 'erpuno/itsm', забезпечуючи неухильне виконання процедур на кожному кроці життєвого циклу інциденту.                                              |

| №                                                                | Вимога з безпеки інформації                           | Вимога ГПБ                                                                        | ЦПБ           |                                                                                                                                                                                                                            |
|------------------------------------------------------------------|-------------------------------------------------------|-----------------------------------------------------------------------------------|---------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                  |                                                       |                                                                                   | Захід захисту | Налаштований зміст заходу захисту                                                                                                                                                                                          |
| 104                                                              | Навчання з реагування на інциденти                    | Параметр: incident_response_training<br>Тип: boolean<br>Значення: true            | IR-2          | Інтерфейс 'eruno/itsm' надає контекстні підказки та інструкції безпосередньо у формах обробки інцидентів, що виконує функцію інтерактивного навчання та підтримки персоналу в кризових ситуаціях.                          |
| 105                                                              | Тестування реагування на інциденти                    | Параметр: incident_testing_simulation<br>Тип: boolean<br>Значення: true           | IR-3          | Можливості ВРЕ-движка дозволяють запускати симуляції інцидентів у тестовому середовищі 'itsm' для регулярного тестування планів реагування без впливу на продуктивну систему.                                              |
| 106                                                              | Обробка інцидентів                                    | Параметр: incident_handling<br>Тип: boolean<br>Значення: true                     | IR-4          | Будь-який інцидент безпеки автоматично реєструється як тикет у модулі 'itsm'. Процес обробки ('incident_management_process') гарантує, що інцидент пройде всі необхідні етапи: виявлення, ізоляція, усунення, відновлення. |
| 107                                                              | Моніторинг інцидентів                                 | Параметр: incident_monitoring<br>Тип: boolean<br>Значення: true                   | IR-5          | Статуси інцидентів у реальному часі відображаються на дашбордах 'eruno/itsm'. ВРЕ-движок дозволяє призначати SLA-таймаут (Boundary Events) для ескалації інцидентів, якщо час реакції перевищено.                          |
| 108                                                              | Звітність про інциденти                               | Параметр: automated_incident_reporting<br>Тип: boolean<br>Значення: true          | IR-6          | Система 'eruno/itsm' автоматично формує звіти про інциденти, надаючи вичерпну інформацію про порушені сервіси, час простою (SLA) та дії команди, що закриває вимоги внутрішньої та зовнішньої звітності.                   |
| 109                                                              | Допомога у реагуванні на інциденти                    | Параметр: incident_assistance<br>Тип: boolean<br>Значення: true                   | IR-7          | Вбудовані засоби комунікації в рамках тикету (коментарі, призначення експертів, інтеграція з базою знань) забезпечують оперативну допомогу та координацію групи безпеки під час інциденту.                                 |
| 110                                                              | План реагування на інциденти                          | Параметр: executable_ir_plan<br>Тип: boolean<br>Значення: true                    | IR-8          | Сам конфігураційний код процесів 'eruno/itsm' виступає в ролі актуального та виконуваного плану реагування на інциденти (Executable Incident Response Plan), усуваючи розбіжність між документацією та реальністю.         |
| 111                                                              | Реагування на витік інформації (Information Spillage) | Параметр: information_spillage_response<br>Тип: boolean<br>Значення: true         | IR-9          | Спеціалізовані BPMN-схеми в 'itsm' передбачені для обробки витоків інформації. Вони включають обов'язкові кроки ідентифікації скомпрометованих даних, блокування доступу ('abac') та сповіщення регулятора.                |
| 10. ОЦІНКА РИЗИКІВ (RA) (RA)                                     |                                                       |                                                                                   |               |                                                                                                                                                                                                                            |
| 112                                                              | Оцінка ризиків                                        | Параметр: risk_assessment<br>Тип: boolean<br>Значення: true                       | RA-3          | Всі ідентифіковані вразливості або загрози фіксуються в реєстрі 'itsm', де їм присвоюється рівень критичності. На базі цього рівня розраховується пріоритет та призначаються відповідальні особи.                          |
| 113                                                              | Сканування вразливостей                               | Параметр: vulnerability_scanning<br>Тип: boolean<br>Значення: true                | RA-5          | Система передбачає можливість інтеграції зовнішніх сканерів вразливостей, звіти яких автоматично перетворюються на тикети усунення ризиків в системі 'itsm'.                                                               |
| 11. ФІЗИЧНИЙ ЗАХИСТ ТА ЗАХИСТ НАВКОЛИШНЬОГО СЕРЕДОВИЩА (PE) (PE) |                                                       |                                                                                   |               |                                                                                                                                                                                                                            |
| 114                                                              | Фізичний доступ                                       | Параметр: physical_access_doc_ref<br>Тип: string<br>Значення: digital-profile.pdf | PE-2          | Регламентується інструкціями з режиму ЦОД (див. розділ PE у digital-profile.pdf).                                                                                                                                          |

| №                                                      | Вимога з безпеки інформації                 | Вимога ГПБ                                                                                | ЦПБ           |                                                                                                                                                                                                                                                                         |
|--------------------------------------------------------|---------------------------------------------|-------------------------------------------------------------------------------------------|---------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                        |                                             |                                                                                           | Захід захисту | Налаштований зміст заходу захисту                                                                                                                                                                                                                                       |
| 115                                                    | Контроль фізичного доступу                  | Параметр: physical_access_control_ref<br>Тип: string<br>Значення: digital-profile.pdf     | PE-3          | Регламентується системами СКУД будівлі (див. розділ PE у digital-profile.pdf).                                                                                                                                                                                          |
| 12. ОБІЗНАНІСТЬ ТА НАВЧАННЯ (AT) (AT)                  |                                             |                                                                                           |               |                                                                                                                                                                                                                                                                         |
| 116                                                    | Навчання з обізнаності щодо безпеки         | Параметр: security_awareness_training_ref<br>Тип: string<br>Значення: digital-profile.pdf | AT-2          | Програми навчання та інструктажі (див. розділ AT у digital-profile.pdf).                                                                                                                                                                                                |
| 117                                                    | Навчання з питань безпеки, залежне від ролі | Параметр: role_based_training_ref<br>Тип: string<br>Значення: digital-profile.pdf         | AT-3          | Спеціалізоване навчання для адміністраторів (див. розділ AT у digital-profile.pdf).                                                                                                                                                                                     |
| 13. УПРАВЛІННЯ РИЗИКАМИ В ЛАНЦЮГУ ПОСТАЧАННЯ (SR) (SR) |                                             |                                                                                           |               |                                                                                                                                                                                                                                                                         |
| 118                                                    | План управління ризиками ланцюга постачання | Параметр: zero_dependency_policy<br>Тип: boolean<br>Значення: true                        | SR-2          | План управління базується на принципі відмови від стороннього коду. Замість інтеграції сотень неперевіраних бібліотек, команда розробляє всі необхідні компоненти (веб-сервер N2O, KVS, CA) самостійно в єдиному монорепозіторії.                                       |
| 119                                                    | Контроль та захист ланцюга постачання       | Параметр: strict_code_vendoring<br>Тип: boolean<br>Значення: true                         | SR-3          | Заборонено використання автоматичних менеджерів пакетів для завантаження коду під час збірки. Весь вихідний код системи та модулів міститься безпосередньо в репозиторії проекту, що гарантує 100% контроль над кожним рядком коду, який компілюється.                  |
| 120                                                    | Аудит та огляди постачальників              | Параметр: erlang_otp_supplier_review<br>Тип: boolean<br>Значення: true                    | SR-6          | Єдиним зовнішнім «постачальником» є розробник платформи Erlang/OTP (компанія Ericsson та спільнота). Оновлення версій OTP проходять жорстку перевірку перед їх застосуванням на продуктивних серверах.                                                                  |
| 121                                                    | Автентичність компонентів                   | Параметр: component_authenticity<br>Тип: boolean<br>Значення: true                        | SR-11         | Будь-які оновлення або патчі самої системи передаються виключно через захищені канали із застосуванням криптографічних підписів ('sync/ca'), що виключає можливість підміни бінарних файлів під час розгортання.                                                        |
| 14. ПЛАНУВАННЯ (PL) (PL)                               |                                             |                                                                                           |               |                                                                                                                                                                                                                                                                         |
| 122                                                    | План безпеки системи                        | Параметр: system_security_plan<br>Тип: boolean<br>Значення: true                          | PL-2          | Система підтримує автоматичну генерацію актуального Плану безпеки системи на основі цього профілю (СМ). План чітко визначає всі технічні та організаційні контролю (AC, AU, SC, CM тощо), середовище функціонування та архітектуру.                                     |
| 123                                                    | Правила поведінки                           | Параметр: rules_of_behavior<br>Тип: boolean<br>Значення: true                             | PL-4          | Для всіх користувачів платформи (організаційних та зовнішніх) визначаються правила поведінки. Згода з правилами (наприклад, Terms of Service, NDA) фіксується в базі даних KVS під час онбордингу, перед наданням доступу до ERP/1.                                     |
| 124                                                    | Архітектура безпеки                         | Параметр: security_architecture<br>Тип: boolean<br>Значення: true                         | PL-8          | Архітектура безпеки платформи (Actor Model, ізоляція процесів, Zero Dependencies, Append-Only логування) розробляється інтегровано з загальною архітектурою підприємства. Вона регулярно переглядається на відповідність державним стандартам (НД ТЗІ, NIST SP 800-53). |